



Anil Seth

Identity Management in an Increasingly Cloudy World

A few best practices systems administrators can follow when planning and implementing an organisation's access control policy.

Security in a complex environment is complicated. However, a really secure system should not impact the user. It must be easy to use or else users will find a workaround. Here's a scenario I have frequently noticed at banks. Roles are defined to different users. Usually, the person entering the data does not have the rights to verify and approve the transaction. While this role definition is desirable and necessary, what is an employee to do if a client is in front of her and the approver is not available. I have seen junior staff members sign in as approvers and clear transactions.

The approver trusts the person at the counter but the system does not! So people find an informal solution to get the job done rather than fight the system. A far better option would be to let the approver delegate authority. This requires a more complex mechanism for authentication but the system would enable users to work as the security policy of the organisation expects them to.

Another irritant that can occur is if there are many applications on many servers, whether physical or in the cloud. The easiest option then appears to be to let users create multiple identities or, at least, multiple passwords. Users may then write passwords on a piece of paper to keep track of their various accounts or may use the same password on every system. In the latter case, the weakest system in the organisation's network can be used as a break-in point. This is almost inevitable as a developer or administrator is not going to make the effort to secure a relatively insignificant application. I have often seen clear text passwords for such applications. It is highly likely that at least some users will use the same password for an unsecured application as they have used for secure applications of the organisation. It creates an opportunity waiting to be exploited.

An obvious solution is to use a directory server for authentication. OpenLDAP is the common solution for the Linux and UNIX environments. Replacing password file authentication by LDAP is not difficult and a suitable tutorial can be easily found for each distribution.

Routers and various server applications can use the same LDAP server for authentication and access rights for the network, applications and roles.

Unfortunately, one group of systems just refuses to merge with the LDAP environment – the Microsoft Windows environments. Windows servers will want to use Active Directory servers, which extend LDAP servers.

It is possible to configure an Active Directory server so that it can be used as an LDAP server for Linux authentication needs. We can't wish it away – even Gentoo has a wiki page explaining how to implement it (http://en.gentoo-wiki.com/wiki/Active_Directory_Authentication_using_LDAP). However, some people may be reluctant to use the Windows environment for all their authentication needs.

Samba 4, currently in beta, will have the capability of being an Active Directory server, and will thus be usable for all applications, either Linux, Windows or dedicated hardware like routers. You can read more about it at <http://wiki.samba.org/index.php/Samba4/HOWTO>.

In the current environment, there is no getting away from keeping two directory servers – one for Windows authentication and one for everything else. Given that constraint, one could use both an LDAP server and Active Directory server but synchronise the two.

The 389 directory server from Fedora includes the option to sync with Active Directory – <http://directory.fedoraproject.org/wiki/Howto:WindowsSync>.

A similar functionality is not available in OpenLDAP, which is the more popular option, so one needs to look at alternative extensions. An example is <http://acctsync.sourceforge.net/> even though it has been inactive for a number of years. Once the synchronisation of accounts works, updates are not really needed. However, there is one more active alternative – <http://lsc-project.org/>, which has a broader goal:

"...to provide a simple and efficient way of synchronizing any data source to a LDAP directory quickly."

This project will use a configuration file to write changes